

Security and Privacy of AI Agents in Blockchain and Web3 Ecosystems: A Systematic Literature Review

Abstract

Artificial intelligence (AI) and blockchain are converging rapidly: machine learning, deep learning, and large language model (LLM) based agents are now used to audit smart contracts, detect fraud, monitor transactions, and reason over on-chain data, while autonomous AI agents are themselves beginning to hold keys, sign transactions, and act inside decentralized finance (DeFi), decentralized applications, and decentralized autonomous organizations (DAOs). This dual role—AI as a defender of blockchain systems and AI as a new attack surface within them—raises security and privacy questions that neither the AI-safety nor the blockchain-security literature has fully addressed in isolation. This review synthesizes the evidence on the security and privacy of AI agents, LLM-based agents, and machine-learning systems in blockchain and Web3 ecosystems. Following the PRISMA 2020 statement and the PRISMA-S search extension, we retrieved 8,481 records from five bibliographic databases covering 2020–2026, de-duplicated them to 4,619 unique records, ranked the corpus by relevance to the review objective, and assessed a prioritized set of 50 highest-ranked full-text reports for eligibility. Thirty-four records (thirty-two unique studies) met the inclusion criteria and were synthesized. We organize the findings around six questions: the AI methods used for blockchain and Web3 security; the security and privacy risks introduced when AI agents interact with wallets, smart contracts, DeFi protocols, and DAOs; the attacks reported against AI-driven blockchain systems; the datasets, benchmarks, tools, and metrics used for evaluation; the mitigation strategies proposed; and the open challenges. The evidence is dominated by smart-contract vulnerability detection (with reentrancy the most studied weakness), fraud and anomaly detection in DeFi, and a fast-growing body of LLM-based and multi-agent auditing work; privacy-preserving learning (federated learning, differential privacy, homomorphic encryption, zero-knowledge proofs) is the most common mitigation theme. In contrast, agent-specific threats—prompt injection, agent hijacking, malicious transaction signing, private-key leakage, and multi-agent collusion—are discussed mostly at the level of taxonomy and position papers rather than measured on blockchain testbeds, and standardized, agent-aware benchmarks are largely absent. We consolidate these gaps into a research agenda for secure, private, and trustworthy AI-driven blockchain and Web3 systems.

Keywords: AI agents; large language models; blockchain security; Web3; smart-contract auditing; DeFi; prompt injection; privacy-preserving machine learning; systematic literature review.

Contents

1	Introduction	3
1.1	Background and motivation	3
1.2	Scope and definitions	3
1.3	Research questions	3
1.4	Contributions	4
1.5	Structure of the review	4

2	Review methodology	4
2.1	Reporting framework	4
2.2	Information sources	4
2.3	Search strategy	4
2.4	Eligibility criteria	5
2.5	Selection process	5
2.6	Data extraction and synthesis	5
2.7	Search, ranking, and synthesis summary	6
2.8	Study selection flow (PRISMA)	6
3	Overview of the evidence base	6
4	RQ1: AI methods for blockchain and Web3 security	8
4.1	Classical machine learning for vulnerability and fraud detection	8
4.2	Deep learning and graph neural networks	15
4.3	Large language models and multi-agent auditing	15
4.4	Privacy-preserving and federated learning	16
4.5	Beyond contracts: oracles, monitoring, and compliance	16
5	RQ2: Security and privacy risks of AI agents in Web3	17
5.1	Agentic AI as a new attack surface	17
5.2	Privacy and trust risks of AI-generated content in Web3	17
5.3	Risks inherited from the learning pipeline	18
6	RQ3: Attacks reported against AI-driven blockchain systems	18
6.1	On-chain and smart-contract exploits	18
6.2	Attacks on the AI defender	18
6.3	Agent-specific and multi-agent attacks	19
7	RQ4: Datasets, benchmarks, tools, and evaluation metrics	19
7.1	Datasets and benchmarks	19
7.2	Tools and frameworks	20
7.3	Evaluation metrics	20
8	RQ5: Mitigation strategies	21
8.1	Privacy-preserving learning	21
8.2	Blockchain as a trust anchor for AI	21
8.3	Explainability, provenance, and content authenticity	21
8.4	Governance, monitoring, and secure agent protocols	21
9	RQ6: Limitations, gaps, and future directions	22
10	Discussion	23
10.1	Cross-cutting themes	23
10.2	Practical implications	23
10.3	Threats to validity	23
11	Conclusion	24

1 Introduction

1.1 Background and motivation

Blockchain and Web3 systems coordinate value, identity, and computation across mutually distrusting parties without a central authority. Their attack surface is correspondingly broad: smart contracts execute irreversibly and hold substantial assets; oracles import off-chain truth that protocols cannot themselves verify; DeFi protocols compose into deep dependency chains; and wallets concentrate the private keys that authorize every action. Conventional auditing and static analysis have repeatedly proven insufficient against sophisticated threats such as reentrancy, integer overflow, front-running, oracle manipulation, flash-loan exploits, and rug pulls [1, 2]. Against this backdrop, AI has been adopted as a defensive technology: machine learning (ML), deep learning (DL), graph neural networks (GNNs), and—most recently—large language models (LLMs) are used to audit contracts, score transactions, detect fraud, evaluate oracle trust, and automate compliance [3–5].

Simultaneously, the relationship is inverting. Autonomous and LLM-based agents are no longer only *analysts* of blockchain data; they increasingly *act* inside Web3—querying chains, holding wallets, signing transactions, interacting with decentralized applications, and participating in DAO governance. When agents gain this kind of agency, classes of risk that are familiar from AI safety (prompt injection, jailbreaking, data and model poisoning, hallucination) acquire irreversible, financial consequences, and multi-agent dynamics introduce wholly new failure modes such as covert collusion and cascade failures [6, 7]. The security and privacy of AI agents in blockchain and Web3 ecosystems therefore sits at the intersection of two literatures that have largely evolved separately, and a consolidated view of what is known—and what is missing—is overdue.

1.2 Scope and definitions

We use the following working definitions throughout. *AI agents* and *LLM agents* denote AI systems (often LLM-based) that perceive an environment and take goal-directed actions, possibly using external tools or calling other agents. *Blockchain and Web3 ecosystems* include public and permissioned ledgers, smart contracts, decentralized applications, DeFi protocols, DAOs, wallets, oracles, and on-chain data. *Security* refers to resistance to adversarial manipulation and preservation of system integrity and availability; *privacy* refers to protection of sensitive data and model information against leakage and inference. The review covers (i) AI methods applied to blockchain and Web3 security tasks, and (ii) the security and privacy risks, attacks, and mitigations that arise when AI agents and AI-driven systems operate within these ecosystems.

1.3 Research questions

The review is organized around six questions (RQ1–RQ6):

- RQ1** What AI methods are used for blockchain and Web3 security, in particular smart-contract auditing, vulnerability detection, fraud detection, and DeFi risk analysis?
- RQ2** What security and privacy risks arise when AI agents, LLM agents, or autonomous AI systems interact with wallets, smart contracts, decentralized applications, DeFi protocols, DAOs, and on-chain data?
- RQ3** What attacks have been reported against AI-driven blockchain systems—including prompt injection, agent hijacking, malicious transaction signing, private-key leakage, model and data poisoning, oracle manipulation, and smart-contract exploitation?
- RQ4** What datasets, benchmarks, tools, and evaluation metrics are used to assess AI-based blockchain security and privacy systems?
- RQ5** What mitigation strategies have been proposed to secure AI agents and AI-driven systems in blockchain and Web3 environments?

RQ6 What are the main limitations, research gaps, and future directions for AI-driven blockchain security, privacy, and trust?

1.4 Contributions

This review makes four contributions. First, it provides a PRISMA-conformant account of a multi-database search and relevance-ranked selection over the 2020–2026 window, with a transparent flow of records from identification to inclusion. Second, it synthesizes the AI methods applied to blockchain and Web3 security into a coherent taxonomy spanning classical ML, deep learning and GNNs, LLM and multi-agent auditing, and privacy-preserving learning. Third, it separates the two faces of the topic that prior surveys often conflate—AI *for* blockchain security versus the security *of* AI agents *within* Web3—and shows that the second is comparatively under-evidenced. Fourth, it consolidates datasets, benchmarks, tools, and metrics, and distills a prioritized agenda of open challenges.

1.5 Structure of the review

Section 2 describes the review methodology and presents the PRISMA flow diagram. Section 3 characterizes the evidence base. Sections 4–9 address RQ1–RQ6 in turn. Section 10 discusses cross-cutting themes and threats to validity, and Section 11 concludes.

2 Review methodology

2.1 Reporting framework

The review was designed and reported in accordance with the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA 2020) statement, together with the PRISMA-S extension for reporting literature searches. The protocol fixed, in advance, the objective, research questions, information sources, search strategy, eligibility criteria, and the data items to be extracted from each included study.

2.2 Information sources

Records were retrieved from five bibliographic databases and indexes that together provide broad coverage of computer-science, security, and multidisciplinary venues: *Crossref*, *OpenAlex*, *Semantic Scholar*, *Europe PMC*, and *PubMed*. To reduce the risk of missing relevant grey and preprint literature characteristic of this fast-moving field, the database searches were complemented by backward and forward citation searching of included studies and by manual searching of major cybersecurity and blockchain conference proceedings, smart-contract security tool repositories, Web3 security reports and technical white papers, and arXiv preprints relating to AI agents, blockchain security, and smart-contract auditing. The search covered the period January 2020 to June 2026 and was restricted to English-language records.

2.3 Search strategy

The search strategy combined three families of query terms—core *platform* concepts (blockchain, Web3, smart contract, DeFi, DAO, cryptocurrency), core *AI* concepts (artificial intelligence, machine learning, deep learning, large language model, LLM agent, AI agent), and core *security and privacy* concepts (blockchain security, Web3 security, smart-contract auditing, vulnerability detection, fraud detection, privacy). These were expressed both as controlled, database-specific Boolean strings (following PRISMA-S guidance on documenting full search strings per source) and as a set of generated natural-language queries, and were executed across the five sources. In total, thirty unique query strings were run against the databases; the productive run rate

(query/database executions returning at least one record) was approximately 71%, with the remainder returning zero results or failing at the source. The full set of executed search strings is retained for auditability.

2.4 Eligibility criteria

Inclusion. Studies were eligible if they: (i) concerned the use of AI, ML, DL, LLMs, generative AI, or AI agents in blockchain, Web3, smart-contract, DeFi, DAO, or cryptocurrency systems; (ii) addressed a blockchain or Web3 security task (smart-contract auditing, vulnerability detection, fraud or scam detection, transaction monitoring, anomaly detection, DeFi risk analysis, phishing detection) *or* examined the security/privacy risks of AI agents interacting with wallets, smart contracts, decentralized applications, DeFi protocols, DAOs, blockchain infrastructure, or on-chain data *or* proposed or evaluated mitigations, benchmarks, datasets, tools, frameworks, or security architectures for AI-driven blockchain systems; (iii) were peer-reviewed articles, conference papers, arXiv preprints, or high-quality technical reports; (iv) were published between January 2020 and June 2026; and (v) were written in English.

Exclusion. Studies were excluded if they discussed blockchain and AI only at a high conceptual level without technical security, privacy, architecture, benchmark, dataset, or evaluation content; addressed only blockchain finance, tokenomics, pricing, or market prediction without cybersecurity or privacy relevance; addressed only consensus, mining, scalability, or performance without AI relevance; addressed only general AI ethics, governance, or policy without concrete blockchain or Web3 security relevance; used the term “agent” in a non-AI or non-blockchain sense; were editorials, opinion pieces, posters, tutorials, abstracts, blog posts, or news items without substantive technical content; were duplicates; were non-English; or fell outside the coverage window.

2.5 Selection process

After de-duplication, the unique corpus was prioritized by relevance to the review objective using two complementary title-and-abstract ranking configurations. The first represented the review *title and objective*; the second represented the broader *review intent*, incorporating the research questions, concepts, search queries, keywords, and eligibility terms. Each configuration scored every record against these representations and produced a ranked list. Agreement between the two configurations was high (their top-1,000 sets overlapped in 838 records, i.e. about 84% of the smaller set), which supports the stability of the ordering. The highest-ranked candidates were carried forward, full text was sought for the top-ranked reports, and the fifty highest-ranked full-text reports were assessed in depth against the eligibility criteria. Each was given an explicit *include/exclude* decision with a recorded rationale; thirty-four records were included and sixteen were excluded with reasons. Full text was available for forty-nine of the fifty assessed reports.

2.6 Data extraction and synthesis

For each included study we extracted bibliographic metadata, study type, objective, study domain, datasets and data sources, attack types and threats considered, systems/tools/frameworks, methods/models/algorithms, evaluation design and metrics, headline numerical results, reported limitations, and relevance to the review questions, together with short supporting evidence snippets to preserve traceability. Because the included studies differ widely in design (surveys, systematic reviews, primary experiments, position papers) and report incommensurable metrics on heterogeneous datasets, a meta-analysis was not appropriate; we therefore use a structured narrative synthesis organized by research question, supported by summary tables.

2.7 Search, ranking, and synthesis summary

Figures 1–6 summarize the search, ranking, and synthesis stages and are referenced from the relevant subsections below. Figure 1 reports the literature-search funnel, per-database contribution, year distribution, and metadata completeness; Figures 2 and 3 report the ranking and full-text ranking validation; and Figures 5 and 6 report the synthesis evidence dashboard and the extracted concept clusters.

2.8 Study selection flow (PRISMA)

Figure 4 presents the PRISMA 2020 flow of records from identification to inclusion. The sixteen exclusions at the eligibility stage fell into three groups: studies whose application domain lay outside blockchain and Web3 (smart cities, smart grids, the Internet of Things, healthcare data, and general cloud security; $n = 6$); general AI-blockchain or AI-finance integration studies that lacked a focus on AI-agent or Web3 security and privacy ($n = 9$); and conceptual or framework papers without empirical or technical security content ($n = 1$).

3 Overview of the evidence base

The synthesized corpus comprises 34 records (32 unique studies; three of the records are versions of a single study on decentralized trust in generative AI). Of the fifty reports assessed in depth, 68% were included and 32% excluded. The evidence base is recent and growing: retained records cluster in 2024–2026, mirroring the rise of LLM-based methods, and span surveys and systematic reviews, primary experimental studies, framework proposals, and position papers. Figure 5 summarizes the synthesis dashboard, and Figure 6 the most frequently extracted concepts across the article-level evidence.

Three observations frame the synthesis that follows. First, the corpus is *strongly weighted toward AI for blockchain security*—smart-contract vulnerability detection and DeFi fraud/anomaly detection—rather than the security of AI agents acting within Web3. Second, *LLMs are the fastest-moving sub-area*, appearing both as auditing tools and as the subject of new agent-specific threat models. Third, *privacy-preserving learning* (federated learning, differential privacy, homomorphic encryption, and zero-knowledge proofs) recurs as the default mitigation vocabulary across otherwise dissimilar studies. Table 1 summarizes the included studies; subsequent sections analyze them by research question.

Table 1: Characteristics of the included studies ($n = 32$ unique studies; three synthesized records are versions of a single study and are cited once). Abbreviations: SLR, systematic literature review; SoK, systematization of knowledge; SC, smart contract; FL, federated learning; DP, differential privacy; HE, homomorphic encryption; ZKP, zero-knowledge proof; GNN, graph neural network.

Study	Yr	Type	Primary focus	Methods / headline evidence
Adamopoulos [8]	2026	Survey	AI+blockchain for smart-finance security	ML/DL/NLP/RL/FL; synthesizes 292 studies; fraud-detection accuracies 95–99%.
Peng [9]	2025	Review	AI-driven blockchain optimization (consensus, SC, privacy, retrieval)	GNN/LSTM/Transformer/FL/DP; DefectChecker F-score 88.8%; CRPWarner precision 91.8%.
Hussain [10]	2025	Framework	GPT+BERT into blockchain for SC generation and fraud detection	BERT fraud detection 94.3% vs. RF 73.1%; 32% latency and 23% energy reduction.

continued on next page

Table 1 – continued

Study	Yr	Type	Primary focus	Methods / headline evidence
Zheyuan He; Zihao Li; Yang; Ye [3]	2024	SLR	LLMs for blockchain security	46 studies across five domains; BLOCKGPT 2,284 tx/s, 49/124 attacks ranked.
Razzak [11]	2025	SLR	ML for SC vulnerability detection	88 studies; KNN/RF/SVM/GNN/hybrid; reentrancy most studied; hybrids near-perfect.
Panwar [12]	2026	Primary	Blockchain-integrated ensemble ML+SHAP for transparent SC vuln. detection	RF/XGBoost/LightGBM/CatBoost; LightGBM 99.2% on SmartBugs-Wild; on-chain registry.
Zhu [13]	2025	Primary	LLM multi-agent SC auditing (LLM-SmartAudit)	GPT-4o multi-agent; 98% common vulns, 47.6% real-world, 12/13 CVEs, ~\$1/contract.
Rahnama [14]	2025	Primary	DeFiSentinel: FL+blockchain+cryptographic SC	FL/DNN/DP/ECC; F1 91.7%, F2 0.96, anomaly accuracy 95.62%.
Vasilakos [15]	2023	Vision	Blockchain for trusted LLMs (BC4LLM)	FL/DP/HE/ZKP/SSI-DID; secures corpus, training, and generated content.
He [5]	2023	Survey	AI fraud detection in DeFi by project life cycle	tree/graph models, NLP, LLMs; taxonomy of 11 fraud types.
Nti IK [16]	2025	Primary	Multi-source explainable AI for transaction manipulation	XGBoost/LightGBM/autoencoder/isolation forest+SHAP; supervised F1>0.96; unsupervised F1≤0.26.
Zhiyuan Wei; Jing Sun; Zhang [17]	2024	Primary	LLM-SmartAudit multi-agent (arXiv)	GPT-3.5/4o; 74% recall on labelled set; 11 new vulns; ~\$1/contract.
Kuppusamy [1]	2026	Review	ML for DeFi security (front-running, oracle, SC)	LSTM/isolation forest/GNN/CodeBERT; dataset and tool catalogue.
Shakir [2]	2025	SLR	DeFi security innovations	DL/RL/NLP detectors; 13 attack types; DeFiRanger precision 0.996.
Rossi [18]	2025	SoK	ML SC vuln. detectors (Ethereum)	26 detectors; GNN/attention/transformers; dataset and labelling flaws identified.
Raju B [19]	2025	Primary	HB3LSTM+SHAP+quantum-inspired feature selection	LSTM/BBO/IQPO/SHAP; 99.68% accuracy; adversarial accuracy drop to 85%.
Caldarelli [20]	2025	Position	Can AI solve the blockchain oracle problem?	anomaly detection/RL/LLMs; AI complements but cannot remove oracle trust.
Al-Radhi [21]	2025	Framework	GenAI trust via decentralized Web3 (seven detection techniques)	FL/blockchain provenance/ZKP/DAO/watermarking/XAI/PPML; EU AI Act alignment.
Roberts [22]	2025	Primary	LLM vs. ML for SC vuln. detection	LSTM/DistilBERT/BERT; DistilBERT weighted-F1 0.93.
S. [23]	2025	Primary	PrivChain-AI: FL+DP+HE+ZKP for private reporting	FL/Transformer/Rényi-DP; 94.7% fraud accuracy; membership inference ≈52%.

continued on next page

Table 1 – continued

Study	Yr	Type	Primary focus	Methods / headline evidence
Elkaffas [24]	2026	Primary	Lightweight blockchain+MobileNet DL fraud detection	MobileNet/PoS/ZK-SNARK; 94.1% accuracy; ZKP cuts membership inference 84.6%→32.3%.
Alevizos [25]	2024	Primary	Automated cyber compliance via AI+blockchain+SC	SecureBERT/RF/smart contracts; compliance enforcement 98% vs. 85% human.
Emmanouilidis [6]	2025	Review	TRiSM for agentic multi-agent AI	governance/security/privacy pillars; risk taxonomy; CSS and TUE metrics.
Wu [26]	2025	Conceptual	ML limitations and data augmentation for SC vuln. detection	semi-supervised/transfer learning; Solidity→Python augmentation.
Sheng [4]	2024	SLR	Ethereum SC vuln. detection and ML	55 studies; classical/DL/ensemble; class-imbalance and unknown-vuln gaps.
Zuo [27]	2025	Primary	MOS: mixture-of-experts tuning of LLMs for SC vuln. detection	MoE LLM; +6.32% F1 over 16 baselines; high-quality explanations.
Luo [28]	2026	Survey	LLMs for SC vuln. detection (GPTLens/SmartVD/FELLMVP)	LLM frameworks; FELLMVP 98.8% accuracy, F1 88%.
Christian Schroeder de Witt; Krawiecka [7]	2025	Position	Open challenges in multi-agent security	threat taxonomy; collusion/swarm/cascade; security is non-compositional.
Nagarjun AV [29]	2025	Primary	Quantum DL-enhanced Ethereum blockchain for cloud security	FL/GNN/VAE/contrastive/Transformer; GNN-AID 98.7%; poisoning −98.4%.
?]	2025	Survey	LLMs for next-generation cybersecurity, incl. blockchain	LLM zero/few-shot; SC auditing and threat simulation; hallucination and misuse risks.
Zhuang [30]	2024	Survey	Blockchain for LLM security and safety	BC4LLMs taxonomy; FL/ZKP/DP; data-poisoning and prompt-injection mitigations.
Tsai [31]	2026	Primary	LLM prompt engineering for SC vuln. detection	GPT-3.5 zero/few-shot+CoT/Plan-and-Solve; best 84% on integer overflow.

4 RQ1: AI methods for blockchain and Web3 security

The largest body of evidence concerns AI methods applied to defensive blockchain tasks: smart-contract auditing and vulnerability detection, fraud and anomaly detection in DeFi, transaction monitoring, and oracle trust evaluation. We organize this evidence by method family—classical ML, deep learning and GNNs, LLM-based and multi-agent methods, and privacy-preserving learning—while noting that many studies combine several families.

4.1 Classical machine learning for vulnerability and fraud detection

Classical supervised learning remains a strong and frequently preferred baseline. A systematic review of 88 studies on ML for smart-contract vulnerability detection found that classical methods— k -nearest neighbours, random forests, decision trees, gradient boosting, and support

Security and privacy of AI agents in blockchain and Web3 ecosystems: a systematic literature review

Literature search summary



Figure 1: Literature-search summary. Of 8,481 raw records retrieved across five databases, 4,619 unique records were retained after de-duplication (a 46% reduction); 98.3% of unique records carried a DOI. Crossref, Europe PMC, and OpenAlex were the largest contributors. Retained records grew steadily from 2021, consistent with the recent emergence of the field, and core metadata fields (title, year, DOI, URL) were near-complete, with abstracts present for 61% of records.

Ranking validation dashboard: Security and privacy of AI agents in blockchain and Web3 ecosystems: a systematic literature review

Top 1,000 records were evaluated using metadata completeness, rank-band scores, configured-term recovery, top-keyword rank decay, source contribution, query-origin contribution, and agreement between the two ranking strategies.



Figure 2: Ranking-validation summary over the top 1,000 ranked records. The two ranking configurations (title/objective and review-intent) showed consistent mean-score decay across rank bands, complete recovery of configured topic terms, and 79–84% top-*N* agreement, supporting the stability of the relevance ordering used for selection.

Full-text ranking dashboard: Security and privacy of AI agents in blockchain and Web3 ecosystems: a systematic literature review

Top 200 full-text-ranked records were evaluated using full-text availability, rank-band scores, keyword rank decay, source contribution, query-origin contribution, and agreement with the preferred/hybrid ranking.



Figure 3: Full-text ranking summary for the prioritized records. Full-text availability and rank-band scores, keyword rank decay, database and query-origin contribution, and ranking agreement are reported. Full text was available for 94% of the prioritized records, and validation terms such as *blockchain*, *security*, *detection*, and *smart* remained concentrated in the highest-ranked band.

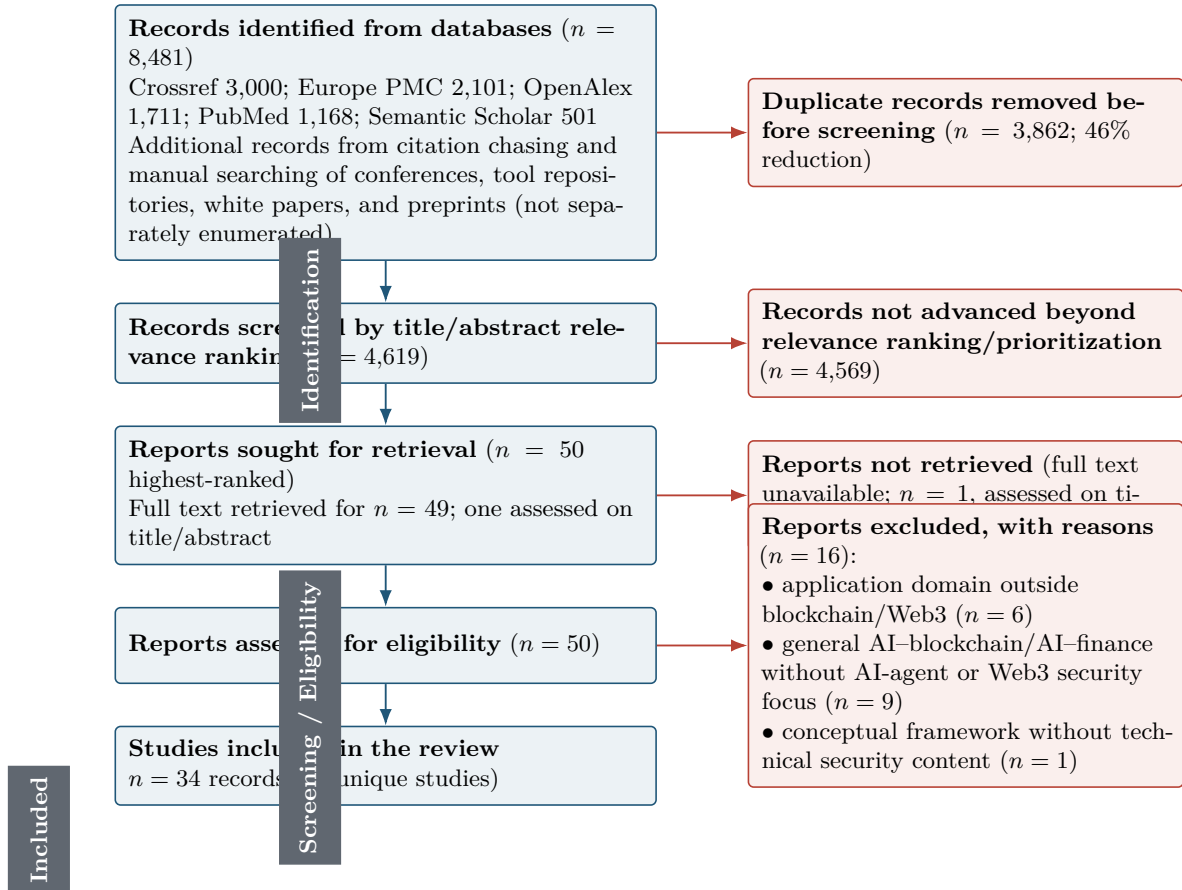


Figure 4: PRISMA 2020 flow diagram for the review. Records were identified from five databases and supplementary sources, de-duplicated, screened by relevance ranking, and the fifty highest-ranked full-text reports were assessed for eligibility, yielding 34 included records (32 unique studies). Counts for the broader full-text retrieval pool and the two ranking configurations are reported in the text and in Figures 2–3.

Synthesis evidence dashboard: Security and privacy of AI agents in blockchain and Web3 ecosystems: a systematic literature review

Article-level model-card outputs from deepseek-v4-flash were summarized for the top 50 full-text-ranked articles across screening decisions, major themes, extracted concepts, evaluation evidence, limitations, and category-level co-occurrence patterns.

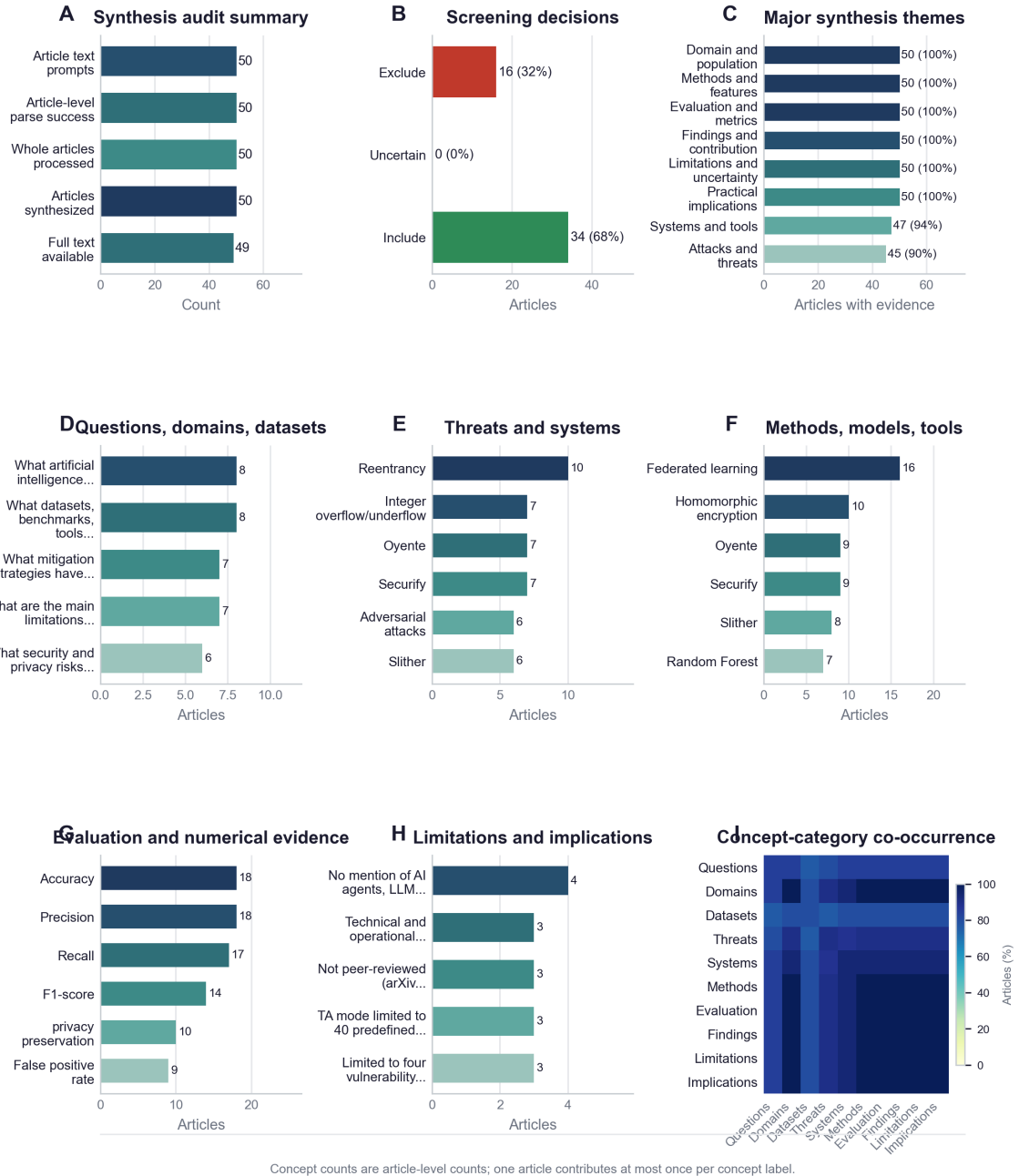


Figure 5: Synthesis evidence dashboard. Across the assessed reports, all major evidence themes (domain and population, methods and features, evaluation and metrics, findings, limitations, and practical implications) were recoverable for 100% of studies, while systems/tools and attacks/threats were reported by 94% and 90% respectively. Reentrancy was the most frequently studied threat; Oyente, Securify, and Slither were the most cited baseline tools; federated learning and homomorphic encryption were the most cited methods; and accuracy, precision, recall, and F1 were the dominant evaluation metrics.

Synthesis concept summary: Security and privacy of AI agents in blockchain and Web3 ecosystems: a systematic literature review

Top extracted concepts from 50 DeepSeek Flash article-level model cards. Each category lists frequent normalized concepts; bars show article-level counts.



Counts are article-level: one article contributes at most once to a concept label. Detailed concept nodes and co-occurrence edges are exported as CSV files.

Figure 6: Top extracted concept clusters across the synthesized evidence, grouped by category (questions, domains, datasets, threats, systems, methods, evaluation, findings, limitations, and implications). Bars show article-level counts; each study contributes at most once per concept label.

vector machines—consistently outperform static-analysis tools, with hybrid models reaching near-perfect detection accuracy, and identified reentrancy as by far the most studied weakness (addressed in 75 of the reviewed papers) [11]. A complementary SLR of 55 Ethereum-focused studies organized methods into classical, deep-learning, and ensemble families and highlighted the dominance of supervised learning, the neglect of unsupervised approaches, and two recurring blind spots: class imbalance and the detection of *unknown* (previously unseen) vulnerabilities [4].

These observations recur in primary studies. A blockchain-integrated framework combining ensemble classifiers (random forest, XGBoost, LightGBM, CatBoost) with SHAP explanations reported up to 99% accuracy on cluster classification of the large SmartBugs-Wild corpus, and—distinctively—wrote predictions on-chain through a *VulnerabilityRegistry* contract so that audit results were themselves immutable and verifiable [12]. For DeFi fraud and transaction-manipulation detection, the same supervised gradient-boosted models dominate: a multi-source explainable-AI framework that fused Ethereum transactions, scam blacklists, and a phishing dataset reported supervised F1 above 0.96 (XGBoost, LightGBM) but unsupervised F1 of at most 0.26 (isolation forest, autoencoder), a striking demonstration of the value of labelled behavioural features—and of the brittleness of unsupervised anomaly detection in this setting [16].

4.2 Deep learning and graph neural networks

Deep learning extends the classical toolkit where code structure and sequence matter. Reviews repeatedly identify GNNs and attention-based models as the most effective deep architectures for capturing the control-flow and data-flow structure of contracts, alongside recurrent and convolutional sequence models over opcode and bytecode [11, 18]. A systematization-of-knowledge study of 26 ML-based Solidity detectors confirmed the popularity and effectiveness of GNNs and attention mechanisms (average reported F1 above 90% for many detectors) but issued an important caution: much of this apparent performance rests on heterogeneous, custom-built datasets labelled by static analyzers of limited accuracy, which undermines comparability and reproducibility [18].

Primary deep-learning systems push reported accuracy higher still, sometimes implausibly so. A hybrid model combining an LSTM variant with branch-and-bound optimization, a quantum-inspired feature-selection step, and SHAP explanations reported 99.68% accuracy on SmartBugs-Wild and generalized across Ethereum and Hyperledger Fabric [19]; the same study, however, showed accuracy collapsing to about 85% under adversarial contracts—a useful reminder that headline accuracy on curated benchmarks can be fragile. At the review level, an analysis of AI-driven blockchain optimization catalogued deep detectors and their reported numbers (for example, DefectChecker at 88.8% F-score and CRPWarner at 91.8% precision for rug-pull detection) while stressing that such figures derive from disparate experimental setups [9].

Deep learning is equally central to DeFi defence. A life-cycle survey of AI-powered DeFi fraud detection mapped fraud types to project stages and found that tree-based models perform best early (small data) while graph-based models dominate later (large, relational data), reporting strong per-task numbers such as LightGBM honeypot detection at 0.993 precision and graph-based phishing detection at 0.928 AUC [5]. A review focused on ML for DeFi security similarly organized methods across front-running detection, oracle-trust evaluation, and contract vulnerability detection, and compiled the public datasets and tools that support them [1].

4.3 Large language models and multi-agent auditing

The fastest-moving sub-area applies LLMs to auditing. An SLR of LLMs for blockchain security categorized 46 studies into smart-contract auditing, transaction-anomaly detection, dynamic anal-

ysis, contract development, and community participation, cataloguing tools such as SMARTINV, GPTScan, and BLOCKGPT (the last processing about 2,284 transactions per second) [3]. Survey work specific to LLM-based detection contrasts representative frameworks—GPTLens (adversarial auditor–critic), SmartVD (domain fine-tuning), and FELL MVP (control-flow+ensemble), the last reporting 98.8% accuracy on 15,000 samples—and identifies hallucination, data scarcity, context limits, and cost as the recurring obstacles [28].

Primary LLM systems substantiate these patterns. *LLM-SmartAudit* uses a multi-agent conversational architecture with a buffer-of-thought mechanism and two analysis modes; across labelled, real-world, and CVE datasets it reached 98% accuracy on common vulnerabilities, identified 12 of 13 CVEs, and—in its arXiv form—uncovered 11 vulnerabilities missed by prior human audits, all at a cost of roughly one US dollar per contract versus hundreds to thousands of dollars for manual audits [13, 17]. *MOS* applies mixture-of-experts tuning so that different experts specialize in different vulnerability classes, improving F1 by 6.32% over sixteen baselines while producing human-rated explanations [27]. Comparative studies show fine-tuned encoder LLMs (DistilBERT) outperforming both classical LSTMs and vanilla BERT on labelled contracts [22], while careful prompt-engineering studies quantify the gains from chain-of-thought and plan-and-solve prompting, reporting a best case of 84% accuracy on integer-overflow detection with few-shot plan-and-solve prompting [31]. A broader survey of LLMs for next-generation cybersecurity situates smart-contract auditing within a wider menu of LLM security applications and flags hallucination and adversarial misuse as cross-cutting risks [?].

A second, integrative strand embeds LLMs directly into blockchain workflows: a layered framework couples GPT (contract generation) with BERT (fraud detection), reporting BERT fraud-detection accuracy of 94.3% against 73.1% for random forest, alongside latency and energy reductions, while explicitly noting vulnerability to adversarial inputs [10].

4.4 Privacy-preserving and federated learning

Across method families, privacy-preserving learning is the most common architectural choice for multi-institution settings. *DeFiSentinel* combines federated learning, blockchain, and cryptographic smart contracts to deliver privacy-preserving risk assessment and DNN-based fraud detection (R^2 0.96, F1 91.7%, anomaly accuracy 95.62%) while keeping institutional data local [14]. *PrivChain-AI* layers differential privacy, homomorphic encryption, and zero-knowledge proofs over blockchain-anchored federated learning, reporting 94.7% fraud-detection accuracy with a membership-inference success rate near random guessing and compliance with multiple regulatory frameworks [23]. A lightweight variant pairs a MobileNet-style detector with a proof-of-stake chain and ZK-SNARKs, showing that zero-knowledge proofs can cut membership-inference accuracy from 84.6% to 32.3% with modest accuracy cost [24]. A quantum deep-learning framework for cloud security integrates blockchain-aware federated learning with GNNs, variational autoencoders, contrastive learning, and transformers, reporting strong intrusion- and fraud-detection numbers and a 98.4% reduction in model-poisoning success through on-chain gradient verification [29]. Broad surveys of AI+blockchain for smart finance and financial information security confirm that this privacy-preserving vocabulary—federated learning, differential privacy, homomorphic encryption, zero-knowledge proofs—is now the default across the field [8, 9].

4.5 Beyond contracts: oracles, monitoring, and compliance

Two tasks broaden RQ1 beyond contract code. First, oracle trust: a position paper argues that AI (anomaly detection, reinforcement learning, LLM-based fact extraction) can materially improve oracle data quality and resilience—one reinforcement-learning oracle reached 92% fraud-detection accuracy versus 78% for a non-learning baseline—but cannot *solve* the oracle problem, because the difficulty is epistemological: models still depend on unverifiable off-chain inputs and add non-determinism, bias, and an enlarged attack surface [20]. Second, automated compliance and

response: a framework integrating SecureBERT and random forests with Hyperledger smart contracts automated security-policy enforcement, reporting compliance-enforcement rates of 98% versus 85% for a human team and order-of-magnitude faster response times in simulation [25].

Summary (RQ1). AI is applied across the blockchain-security stack, but the centre of gravity is smart-contract vulnerability detection and DeFi fraud/anomaly detection. Classical ensembles remain strong and explainable; GNNs and attention models capture code structure; LLM and multi-agent systems are rapidly maturing and uniquely able to surface complex logic flaws and provide explanations; and privacy-preserving learning is the standard answer to multi-institution data constraints. The recurring caveat—raised by the most careful reviews—is that high reported accuracies rest on heterogeneous, often statically labelled datasets, limiting comparability.

5 RQ2: Security and privacy risks of AI agents in Web3

RQ2 concerns the inverse direction: the risks created when AI agents and AI-driven systems *operate within* blockchain and Web3, interacting with wallets, smart contracts, decentralized applications, DeFi protocols, DAOs, and on-chain data. Here the evidence is thinner and more conceptual, and is supplied chiefly by agent-security reviews and position papers rather than by blockchain-specific experiments.

5.1 Agentic AI as a new attack surface

A review of Trust, Risk, and Security Management (TRiSM) for LLM-based agentic multi-agent systems provides the most systematic account. It organizes agent-specific risks—prompt injection, memory poisoning, tool-use abuse, autonomy abuse, agent-orchestration compromise, goal misalignment, and multi-agent collusion or drift—under a structured taxonomy and maps them to five control pillars (explainability, model operations, application security, model privacy, and governance) [6]. Although the review is not blockchain-specific, its risk taxonomy transfers directly: an agent that holds a wallet and calls external tools is exactly the configuration in which prompt injection, tool misuse, and orchestration compromise translate into malicious transaction signing and asset loss.

A complementary position paper on multi-agent security argues that security in systems of interacting agents is *non-compositional*: individually safe agents can compose into unsafe systems [7]. It catalogues threats that have no single-agent analogue—covert collusion via steganographic communication, swarm and heterogeneous attacks, oversight evasion, and cascade failures in which a single adversarial input propagates across many agents—and explicitly lists blockchain-relevant harms (malicious transaction signing, private-key leakage, smart-contract manipulation, oracle abuse) among the threats that multi-agent ecosystems will need to contain. Empirical results it summarizes are sobering: a heterogeneous attack combining a refusal-trained model with a more permissive one raised attack success to 43% (versus under 3% for either alone), and a single adversarial image could, in principle, infect up to a million multimodal agents in a logarithmic number of hops.

5.2 Privacy and trust risks of AI-generated content in Web3

Privacy risk in Web3 also extends to provenance and trust in AI-generated content. A framework on decentralized trust for generative AI treats blockchain, DAOs, and data cooperatives as instruments for mitigating AI-generated misinformation and protecting data sovereignty, proposing seven detection techniques (federated learning, blockchain provenance tracking, zero-knowledge proofs, DAO crowdsourced verification, watermarking, explainable AI, and privacy-preserving machine learning) aligned with emerging regulation [21]. The framing reframes RQ2 partly

as a *trust* problem: when agents generate content or decisions that flow on-chain, provenance, authenticity, and privacy of the underlying data become security properties in their own right.

5.3 Risks inherited from the learning pipeline

Finally, several studies surface risks that AI agents inherit from their learning pipelines and that become acute in financial, irreversible settings: data and model poisoning, adversarial examples, membership-inference and reconstruction attacks, and privacy leakage of training or transaction data [23, 24, 30]. A holistic survey of blockchain for LLM security frames these as systemic LLM vulnerabilities (data poisoning, jailbreaking, inference attacks, prompt injection) and argues that blockchain’s immutability and traceability can partially address them—while conceding that prompt injection, jailbreaking, and retrieval-augmented-generation attacks remain under-defended [30].

Summary (RQ2). The risk surface of AI agents in Web3 is articulated mainly at the level of taxonomy and position papers [6, 7, 21], with concrete, blockchain-situated measurements rare. The dominant identified risks—prompt injection, agent hijacking, malicious transaction signing, private-key leakage, model/data poisoning, oracle abuse, and multi-agent collusion—are precisely those whose consequences are amplified by the irreversibility and value-bearing nature of on-chain action. This is the clearest gap in the literature and is revisited under RQ6.

6 RQ3: Attacks reported against AI-driven blockchain systems

RQ3 consolidates the specific attacks reported across the corpus, distinguishing attacks *on the chain* that AI is used to detect from attacks *on the AI* that defends or acts within it. Table 2 summarizes the threat landscape and the studies that treat each class.

6.1 On-chain and smart-contract exploits

The most frequently studied threats are classic contract weaknesses—reentrancy (the single most studied vulnerability across the corpus), integer overflow/underflow, unchecked external calls, access-control flaws, timestamp dependence, delegatecall misuse, and denial of service—together with DeFi-protocol attacks such as front-running, oracle/price manipulation, flash-loan exploits, and rug pulls, and ecosystem frauds such as Ponzi schemes, honeypots, wash trading, and phishing [1, 2, 5, 11, 18]. A systematic review of DeFi security innovations quantified the distribution, finding oracle manipulation (40% of studies), price manipulation, and flash-loan attacks to be the most frequently targeted, and catalogued detection tools such as DeFiRanger (0.996 precision) and CRPWarner (88.7% F1) [2].

6.2 Attacks on the AI defender

A second, growing class targets the AI itself. Adversarial perturbation, data and model poisoning, and evasion degrade detector performance: one survey reported adversarial perturbations driving CNN misclassification to 86.8% and data-poisoning succeeding in 42% of deployed systems [8], and a primary detector that reached 99.68% accuracy on clean contracts fell to about 85% on adversarial contracts [19]. Membership-inference and reconstruction attacks threaten the privacy of training and transaction data, motivating the differential-privacy and zero-knowledge defences discussed under RQ5 [23, 24]. On-chain gradient verification has been used specifically to blunt model poisoning in federated settings, reportedly reducing poisoning success by 98.4% [29].

6.3 Agent-specific and multi-agent attacks

The third class—prompt injection, agent hijacking, memory poisoning, tool-use abuse, malicious transaction signing, private-key leakage, and multi-agent collusion—is the most consequential for autonomous Web3 agents and the least empirically grounded in blockchain settings. It is articulated chiefly by the two agent-security reviews, which document heterogeneous attacks, steganographic collusion, oversight evasion, and infectious cascade attacks, and by the blockchain-for-LLM survey, which lists prompt injection and jailbreaking among the least-defended LLM threats [6, 7, 30]. Notably, both reviews name blockchain-specific harms—malicious transaction signing, private-key leakage, smart-contract manipulation, oracle abuse, and AI-assisted exploit generation—as in-scope threats for AI agents, even though quantitative blockchain-situated evaluations of these attacks are largely absent.

Table 2: Threat landscape for AI-driven blockchain and Web3 systems, grouped by target, with representative studies.

Class	Representative threats	Representative studies
On-chain / smart-contract exploits	Reentrancy; integer overflow/underflow; unchecked calls; access-control flaws; timestamp dependence; delegatecall misuse; denial of service	[4, 11, 18]
DeFi-protocol attacks	Oracle/price manipulation; front-running and sandwiching; flash-loan exploits; rug pulls; MEV	[1, 2, 20]
Ecosystem fraud	Ponzi schemes; honeypots; wash trading; phishing; money laundering; pump-and-dump	[5, 16]
Attacks on the AI defender	Adversarial perturbation; data/model poisoning; evasion; membership inference; reconstruction	[19, 23, 29]
Agent-specific / multi-agent	Prompt injection; agent hijacking; memory poisoning; tool-use abuse; malicious transaction signing; private-key leakage; multi-agent collusion; cascade failure	[6, 7, 30]

Summary (RQ3). The corpus is rich on on-chain exploits and the attacks AI is used to detect, moderately developed on attacks against the AI defender (adversarial, poisoning, privacy-inference), and thin—at the level of taxonomy rather than measurement—on the agent-specific attacks that matter most for autonomous Web3 agents.

7 RQ4: Datasets, benchmarks, tools, and evaluation metrics

7.1 Datasets and benchmarks

Smart-contract security research converges on a small set of Ethereum-centric resources—most prominently the *SmartBugs* family (Curated and Wild), *SolidiFI*, the *ESC* reentrancy/timestamp datasets, and curated CVE and Code4rena collections—supplemented by transaction datasets such as the *Elliptic* dataset and Etherscan-derived corpora for fraud and phishing detection [5, 12, 13, 16, 18]. The SoK study is emphatic that these datasets are a weak point: many works build custom datasets labelled by static analyzers of limited accuracy, classes are imbalanced, non-vulnerable contracts are often excluded, and code/dataset availability is inconsistent—so reported numbers are frequently non-comparable [18]. The Ethereum SLR independently flags class imbalance and the absence of a standard benchmark as central obstacles [4], and a conceptual study proposes data augmentation (including Solidity-to-Python transformation) and transfer learning to address data scarcity [26].

For agentic AI, evaluation resources are entirely different in character: the TRiSM review points to security benchmarks such as HarmBench, JailbreakBench, ToolBench, AgentBench, GAIA, and WebArena [6], and the blockchain-for-LLM survey compiles datasets relevant to LLM security [30]. Crucially, *none of these is blockchain-situated*: there is no benchmark that measures, for example, an agent’s resistance to prompt-injection-induced malicious signing against a DeFi testbed.

7.2 Tools and frameworks

Across the corpus, the recurring static-analysis baselines are *Oyente*, *Securify*, *Slither*, *Mythril*, *SmartCheck*, and *Maian*, against which ML and LLM detectors are routinely compared [4, 13, 18]. A distinct family of LLM auditing tools—SMARTINV, GPTScan, BLOCKGPT, LLM4FUZZ, GPTLens, SmartVD, FELL MVP, LLM-SmartAudit, and MOS—defines the current frontier [3, 13, 27, 28], and DeFi-specific detectors such as DeFiRanger, CRPWarner, DeFort, and DeFiScanner populate the fraud/exploit side [2].

7.3 Evaluation metrics

Evaluation is dominated by classification metrics: accuracy, precision, recall, and F1 are near-universal, followed by AUC-ROC and false-positive rate (Figure 5). Privacy-preserving studies add privacy- and cost-oriented metrics—privacy budget ϵ , membership-inference success rate, reconstruction risk, communication overhead, and latency [23, 24]—and LLM auditing studies add cost-per-contract and vulnerability-type coverage [13]. The agentic-AI literature, by contrast, proposes purpose-built measures such as the Component Synergy Score and Tool Utilization Efficacy and security-specific rates such as attack-success and defense-effectiveness [6], but these have not yet been instantiated on blockchain workloads. Table 3 summarizes the resource landscape.

Table 3: Datasets, tools, and metrics commonly used across the corpus.

Resource type		Commonly used instances
SC datasets	vulnerability	SmartBugs-Curated / SmartBugs-Wild; SolidiFI; ESC; DAPPSCAN; CVE/Code4rena collections.
Fraud datasets	transaction	Elliptic dataset; Etherscan-derived transaction corpora; phishing-scam datasets; honeypot and Ponzi datasets.
Static-analysis	base-lines	Oyente, Securify, Slither, Mythril, SmartCheck, Maian.
LLM / agent auditing tools		SMARTINV, GPTScan, BLOCKGPT, LLM4FUZZ, GPTLens, SmartVD, FELL MVP, LLM-SmartAudit, MOS.
DeFi detectors		DeFiRanger, CRPWarner, DeFort, DeFiScanner, BLOCKEYE.
Agentic-AI benchmarks	security	HarmBench, JailbreakBench, ToolBench, AgentBench, GAIA, WebArena (<i>not blockchain-situated</i>).
Core metrics		Accuracy, precision, recall, F1, AUC-ROC, false-positive rate; privacy budget ϵ , membership-inference rate, reconstruction risk; cost-per-contract, vulnerability coverage; CSS, TUE, attack-success rate.

Summary (RQ4). A mature but fragmented benchmark culture exists for smart-contract vulnerability detection, hampered by inconsistent labelling and the absence of a standard benchmark; fraud detection reuses a handful of transaction datasets; and agentic-AI evaluation,

while methodologically rich, has *no* blockchain-situated benchmark—a gap that directly limits progress on RQ2 and RQ3.

8 RQ5: Mitigation strategies

Mitigation strategies cluster into four overlapping groups.

8.1 Privacy-preserving learning

The dominant strategy combines federated learning with differential privacy, homomorphic encryption, and zero-knowledge proofs to enable collaborative detection without exposing raw data. DeFiSentinel and PrivChain-AI exemplify the approach, the latter layering all three cryptographic mechanisms over blockchain-anchored federated learning and reporting strong accuracy with near-random membership-inference success [14, 23]. Zero-knowledge proofs are shown to be a practical privacy lever, cutting membership-inference accuracy by more than half in a lightweight blockchain detector [24], and on-chain gradient verification is used to neutralize model poisoning in federated settings [29].

8.2 Blockchain as a trust anchor for AI

A symmetric strategy uses blockchain to secure AI rather than AI to secure blockchain. BC4LLM proposes blockchain-based mechanisms for a reliable learning corpus, a secure (poisoning- and adversary-resistant) training process, and identifiable, traceable generated content via self-sovereign identity and decentralized identifiers [15]. The blockchain-for-LLM survey systematizes this into a taxonomy (BC4LLMs) of blockchain defences against data poisoning, backdoor, and inference attacks, while candidly noting that prompt injection and jailbreaking remain poorly addressed [30]. On-chain verifiability is also used at the detector level: writing predictions to an immutable registry makes audit results themselves tamper-evident [12].

8.3 Explainability, provenance, and content authenticity

Explainable AI (notably SHAP) recurs as a mitigation that improves auditability and trust in detector outputs [16, 19]. For AI-generated content in Web3, blockchain provenance tracking, watermarking, zero-knowledge content authentication, and DAO-based crowdsourced verification are proposed as complementary trust mechanisms [21]. At the architecture level, multi-stage validation of LLM-generated contracts and the combination of LLM auditing with formal verification are recommended to contain hallucination and false positives [10, 13].

8.4 Governance, monitoring, and secure agent protocols

For agentic systems, mitigation shifts from model-level defences to *system-level* controls: runtime monitoring, access control, adversarial training, secure inter-agent protocols, provenance tracking, containment, and governance aligned to regulatory frameworks [6, 7]. The TRiSM review maps these controls to international standards (EU AI Act, NIST AI RMF, ISO/IEC, GDPR), and the multi-agent-security paper calls for secure-by-design interaction protocols and threat-attribution methods, observing that improving one security property can degrade another and that defences must be evaluated for these trade-offs. Automated, smart-contract-enforced compliance and response is an early instantiation of this system-level direction [25]. Table 4 maps mitigation families to the risks they address.

Table 4: Mitigation families, mechanisms, and the risks they primarily address.

Family	Mechanisms	Primary risks addressed
Privacy-preserving learning	Federated learning; differential privacy; homomorphic encryption; zero-knowledge proofs	Data leakage; membership inference; model poisoning
Blockchain as trust anchor for AI	Provenance of corpus/training; on-chain prediction registries; SSI/DID for generated content	Data/model poisoning; tampering; non-repudiation
Explainability & authenticity	SHAP/XAI; watermarking; ZK content authentication; DAO verification	Opaque decisions; AI-generated misinformation
Governance & secure agent protocols	Runtime monitoring; access control; secure inter-agent protocols; containment; standards alignment	Prompt injection; agent hijacking; multi-agent collusion

Summary (RQ5). Mitigation is best developed for privacy (cryptographic and federated learning) and for using blockchain to harden AI pipelines; it is weakest exactly where RQ2/RQ3 are weakest—robust, evaluated defences against prompt injection, agent hijacking, and multi-agent collusion in on-chain settings remain largely aspirational.

9 RQ6: Limitations, gaps, and future directions

Synthesizing the limitations reported across the corpus—present in 100% of the assessed studies—yields a consistent agenda.

1. The security of AI agents in Web3 is under-evidenced. The corpus is dominated by AI *for* blockchain security; the security *of* autonomous agents acting on-chain is treated mainly in taxonomy and position papers [6, 7, 21]. Closing this gap requires experimental studies that situate prompt injection, agent hijacking, malicious signing, and multi-agent collusion on realistic DeFi and DAO testbeds.

2. Benchmarks are fragmented and not agent-aware. Smart-contract datasets are heterogeneous, often statically labelled, class-imbalanced, and of inconsistent availability, undermining comparability [4, 18]; and no blockchain-situated benchmark exists for agentic-AI security. A standardized, shared benchmark—spanning vulnerability detection, fraud detection, and agent-action safety—is the single most enabling missing resource.

3. Headline accuracy can be fragile and over-stated. Several primary detectors report near-ceiling accuracy on curated benchmarks yet degrade sharply under adversarial inputs [19], and reviews caution that aggregated numbers are drawn from incommensurable setups [9, 18]. Adversarial robustness evaluation, not just clean accuracy, should be standard.

4. LLM-specific failure modes are unresolved. Hallucination, false positives, context limits, cost, and reliance on commercial APIs recur as limitations of LLM auditing [13, 28?], and prompt injection and jailbreaking remain poorly defended even in blockchain-for-LLM proposals [30]. Human-in-the-loop auditing, retrieval grounding, multi-agent cross-checking, and hybrid LLM+formal- verification pipelines are the leading proposed remedies.

5. Privacy–utility and security–security trade-offs need characterization. Cryptographic privacy adds computational and communication overhead and can degrade utility or coordination [7, 23]; future work should quantify these trade-offs at deployment scale, including under quantum-resistant assumptions.

6. Oracle and cross-chain trust remain open. AI can improve but not solve oracle trust [20]; verifiable computation for AI outputs (e.g. zero-knowledge ML), robust cross-verification, and clear accountability frameworks are needed before AI oracles can be trusted in high-value DeFi.

7. Governance must become operational. Agent-security reviews map controls to regulation [6, 21], but operational, testable governance for on-chain agents—secure interaction protocols, provenance, attribution, and containment—is largely future work [7].

10 Discussion

10.1 Cross-cutting themes

Three themes cut across the synthesis. First, *AI and blockchain are mutually reinforcing security technologies*: AI supplies adaptive detection and reasoning, blockchain supplies tamper-evidence, provenance, and verifiable audit trails, and the strongest studies exploit both directions at once—using AI to detect threats and blockchain to make the detector’s outputs and the model’s training trustworthy [12, 15, 29]. Second, *the field is bifurcating into a mature defensive sub-field and an immature agent-security sub-field*. Smart-contract auditing and DeFi fraud detection are well populated with datasets, tools, baselines, and metrics; the security of autonomous agents acting in Web3 is, by contrast, mostly prospective. Third, *privacy-preserving learning has become the lingua franca of mitigation*, to the point where federated learning, differential privacy, homomorphic encryption, and zero-knowledge proofs appear as a near-default bundle across otherwise unrelated studies.

10.2 Practical implications

For practitioners, the evidence supports several near-term recommendations: prefer hybrid pipelines that pair ML/LLM detectors with formal verification and human review rather than relying on a single model [13, 28]; treat reported clean-data accuracy with caution and demand adversarial-robustness evidence [19]; adopt zero-knowledge and federated techniques where multi-party data sharing is required [23, 24]; and, for any deployment of autonomous on-chain agents, impose system-level controls—scoped permissions, transaction simulation, runtime monitoring, and human approval for high-value actions—because model-level defences against prompt injection and hijacking are not yet reliable [6, 7].

10.3 Threats to validity

Several limitations of this review should be borne in mind. The synthesis prioritized the fifty highest-ranked full-text reports rather than every retrieved record; while relevance ranking was validated across two configurations with high agreement (Figures 2–3), highly relevant but lower-ranked or harder-to-retrieve studies may have been missed. The restriction to English-language records published from 2020 onward excludes earlier and non-English work. The corpus skews toward Ethereum and Solidity, limiting generalization to other chains and execution environments. Many included primary studies report results on heterogeneous, sometimes weakly labelled datasets, so quantitative figures quoted here should be read as indicative rather than

directly comparable. Finally, the field is moving quickly—particularly around LLM agents—so the most recent developments may post-date the search window.

11 Conclusion

This review synthesized 34 records (32 unique studies) on the security and privacy of AI agents, LLM agents, and machine-learning systems in blockchain and Web3 ecosystems, selected from 8,481 records via a PRISMA-conformant, relevance-ranked process. The evidence shows a mature and productive use of AI *for* blockchain security—especially smart-contract vulnerability detection (with reentrancy the most studied weakness) and DeFi fraud and anomaly detection—spanning classical ensembles, deep learning and GNNs, and a rapidly advancing body of LLM and multi-agent auditing work, with privacy-preserving learning as the default mitigation. It also shows that the inverse and increasingly urgent problem—the security of autonomous AI agents that hold keys and act inside Web3—remains comparatively under-evidenced, treated mostly through taxonomies and position papers rather than measured on blockchain testbeds. The clearest priorities are therefore a standardized, agent-aware benchmark; experimental studies of prompt injection, agent hijacking, malicious signing, and multi-agent collusion in realistic on-chain settings; adversarial-robustness evaluation as standard practice; and operational, testable governance for on-chain agents. Addressing these would move the field from securing blockchains *with* AI toward securing the AI agents that will increasingly act *within* them.

References

- [1] Dhivyalakshmi Venkatraman; Manikandan Kuppusamy. Securing defi: a comprehensive review of ml approaches for detecting smart contract vulnerabilities and threats. *International Journal of Informatics and Communication Technology (IJ-ICT)*, 2026. doi: 10.11591/ijict.v15i1.pp438-446. URL <https://doi.org/10.11591/ijict.v15i1.pp438-446>.
- [2] Chnar Mohammed Kareem; Ahmed Chalak Shakir. A systematic review of security innovations in decentralized finance (defi) using blockchain technology. *Informatica*, 2025. doi: 10.31449/inf.v49i33.7990. URL <https://doi.org/10.31449/inf.v49i33.7990>.
- [3] Ao; Zhang Xiaosong; Luo Xiapu; Chen Ting Zheyuan He; Zihao Li; Sen Yang; Ye, He; Qiao. Large language models for blockchain security: A systematic literature review. *arXiv (Cornell University)*, 2024. doi: 10.48550/arxiv.2403.14280. URL <https://doi.org/10.48550/arxiv.2403.14280>.
- [4] Rasoul Kiani; Victor S. Sheng. Ethereum smart contract vulnerability detection and machine learning-driven solutions: A systematic literature review. *Electronics*, 2024. doi: 10.3390/electronics13122295. URL <https://doi.org/10.3390/electronics13122295>.
- [5] Bingqiao Luo; Zhang Zhen; Qian Wang; Anli Ke; Shengliang Lu; Bingsheng He. Ai-powered fraud detection in decentralized finance: A project life cycle perspective. *arXiv (Cornell University)*, 2023. doi: 10.48550/arxiv.2308.15992. URL <https://doi.org/10.48550/arxiv.2308.15992>.
- [6] Shaina Raza; Ranjan Sapkota; Manoj Karkee; Christos Emmanouilidis. Trism for agentic ai: A review of trust, risk, and security management in llm-based agentic multi-agent systems. *ArXiv.org*, 2025. doi: 10.48550/arxiv.2506.04133. URL <https://doi.org/10.48550/arxiv.2506.04133>.
- [7] Igor; Hagag Ben; Anderson William L.; Belcak Peter; Bucknall Ben; Cai Xiaohong; Chopra Ayush; Cohen Doron; Del Rosario Ron F.; Draguns Andis; Gray Annie; Katz Keren;

- Mavroudis Vasilios; Mink Jaron; Motwani Sumeet Ramesh; Petit Jonathan; Rembeck Leif-Sebastian; Smith Chandler Christian Schroeder de Witt; Krawiecka, Klaudia; Krawczuk. Open challenges in multi-agent security: Towards secure systems of interacting ai agents. *arXiv (Cornell University)*, 2025. doi: 10.48550/arxiv.2505.02077. URL <https://doi.org/10.48550/arxiv.2505.02077>.
- [8] Guma Ali; Otim Emmanuel; Maad M. Mijwil; Bosco Apparatus Buruga; Aida Vafae Eslahi; Ioannis Adamopoulos. A survey on securing smart finance using artificial intelligence and blockchain. *Shifra.*, 2026. doi: 10.70470/shifra/2026/001. URL <https://doi.org/10.70470/shifra/2026/001>.
 - [9] Fujiang Yuan; Zihao Zuo; Yang Jiang; Wenzhou Shu; Zhen Tian; Chenxi Ye; Junye Yang; Zebing Mao; Xia Huang; Shaojie Gu; Yanhong Peng. Ai-driven optimization of blockchain scalability, security, and privacy protection. *Algorithms*, 2025. doi: 10.3390/a18050263. URL <https://doi.org/10.3390/a18050263>.
 - [10] Rana Hassam Ahmed; Jabeen Sultana; Samraiz Zahid; Muhammad Asif Habib; A. Rauf; Majid Hussain. Integrating large language models and ai into blockchain: A framework for intelligent smart contracts and fraud detection. *IEEE Access*, 2025. doi: 10.1109/access.2025.3622511. URL <https://doi.org/10.1109/access.2025.3622511>.
 - [11] Christopher De Baets; Basem Suleiman; Armin Chitizadeh; Imran Razzak. Machine learning approaches for vulnerability detection in smart contracts. *Research Square*, 2025. doi: 10.21203/rs.3.rs-6691317/v1. URL <https://doi.org/10.21203/rs.3.rs-6691317/v1>.
 - [12] Ankit Vishnoi; Varun Sapra; Luxmi Sapra; Preeti Narooka; Deepak Panwar. Blockchain-integrated machine learning framework for transparent smart contract vulnerability detection. *Frontiers in Blockchain*, 2026. doi: 10.3389/fbloc.2026.1735510. URL <https://doi.org/10.3389/fbloc.2026.1735510>.
 - [13] Zhiyuan Wei; Jing Sun; Yuqiang Sun; Ye Liu; Daoyuan Wu; Zijian Zhang; Xianhao Zhang; Meng Li; Yang Liu; Chunmiao Li; Mingchao Wan; Jin Dong; Liehuang Zhu. Advanced smart contract vulnerability detection via llm-powered multi-agent systems. *IEEE Transactions on Software Engineering*, 2025. doi: 10.1109/tse.2025.3597319. URL <https://doi.org/10.1109/tse.2025.3597319>.
 - [14] Seyed Mani Rahnema. Defisentinel: Ai-enhanced decentralized finance architecture with advanced cryptographic smart contracts for data integrity and threat resilience. *IEEE Access*, 2025. doi: 10.1109/access.2025.3568842. URL <https://doi.org/10.1109/access.2025.3568842>.
 - [15] Haoxiang Luo; Jian Luo; Athanasios V. Vasilakos. Bc4llm: Trusted artificial intelligence when blockchain meets large language models. *arXiv (Cornell University)*, 2023. doi: 10.48550/arxiv.2310.06278. URL <https://doi.org/10.48550/arxiv.2310.06278>.
 - [16] Boateng S Weyori BA Adekoya AF. Nti IK, Nyarko-Boateng O. Multi-source explainable ai for blockchain transaction manipulation detection using supervised and unsupervised models. 2025. doi: 10.21203/rs.3.rs-6549946/v1. URL <https://doi.org/10.21203/rs.3.rs-6549946/v1>.
 - [17] Meng; Hou Zhe Zhiyuan Wei; Jing Sun; Zhang, Zijiang; Xianhao Zhang; Li. Llm-smartaudit: Advanced smart contract vulnerability detection. *arXiv (Cornell University)*, 2024. doi: 10.48550/arxiv.2410.09381. URL <https://doi.org/10.48550/arxiv.2410.09381>.

- [18] Dalila Ressi; Alvisè Spanò; Lorenzo Benetollo; Michele Bugliesi; Carla Piazza; Sabina Rossi. Vulnerability detection in solidity smart contracts via machine learning: A qualitative analysis. *ARCA (Università Ca' Foscari Venezia)*, 2025. doi: 10.1016/j.bcra.2025.100390. URL <https://doi.org/10.1016/j.bcra.2025.100390>.
- [19] K GD. Raju B. An elegant intellectual engine towards automation of blockchain smart contract vulnerability detection. *Scientific reports*, 2025. doi: 10.1038/s41598-025-08870-x. URL <https://doi.org/10.1038/s41598-025-08870-x>.
- [20] Giulio Caldarelli. Can artificial intelligence solve the blockchain oracle problem? unpacking the challenges and possibilities. *Frontiers in Blockchain*, 2025. doi: 10.3389/fbloc.2025.1682623. URL <https://doi.org/10.3389/fbloc.2025.1682623>.
- [21] Igor Calzada; Géza Németh; Mohammed Salah Al-Radhi. Trustworthy ai for whom? genai detection techniques of trust through decentralized web3 ecosystems. *Big Data and Cognitive Computing*, 2025. doi: 10.3390/bdcc9030062. URL <https://doi.org/10.3390/bdcc9030062>.
- [22] S M Mostaq Hossain; Amani Altarawneh; Jesse Roberts. Leveraging large language models and machine learning for smart contract vulnerability detection. *2025 IEEE 15th Annual Computing and Communication Workshop and Conference (CCWC)*, 2025. doi: 10.1109/ccwc62904.2025.10903869. URL <https://doi.org/10.1109/ccwc62904.2025.10903869>.
- [23] Alaklabi S. Privchain-ai leveraging blockchain and federated learning for private financial reporting and access control. *Scientific reports*, 2025. doi: 10.1038/s41598-025-32606-6. URL <https://doi.org/10.1038/s41598-025-32606-6>.
- [24] Saad M. Darwish; Samah EL-Naggar; Saleh M. Elkaffas. Securing financial transactions: exploring the role of lightweight blockchain-enabled deep learning for fraud detection in fintech systems. *Cybersecurity*, 2026. doi: 10.1186/s42400-025-00436-8. URL <https://doi.org/10.1186/s42400-025-00436-8>.
- [25] Lampis Alevizos. Automated cybersecurity compliance and threat response using ai, blockchain and smart contracts. *International Journal of Information Technology*, 2024. doi: 10.1007/s41870-024-02324-9. URL <https://doi.org/10.1007/s41870-024-02324-9>.
- [26] Yinuo Wu. Research on security vulnerability detection of blockchain smart contracts based on machine learning. *Applied and Computational Engineering*, 2025. doi: 10.54254/2755-2721/2025.20839. URL <https://doi.org/10.54254/2755-2721/2025.20839>.
- [27] Hang Yuan; Lei Yu; Zhirong Huang; Jingyuan Zhang; Junyi Lu; Shiqiang Cheng; Yang Li; Fengjun Zhang; Jiajia Ma; Chun Zuo. Mos: Towards effective smart contract vulnerability detection through mixture-of-experts tuning of large language models. *ArXiv.org*, 2025. doi: 10.48550/arxiv.2504.12234. URL <https://doi.org/10.48550/arxiv.2504.12234>.
- [28] Yun Li; YanLing Liu; ChangEr Liu; XinMan Luo. Application of large language models in smart contract vulnerability detection. *Journal of Computer Science and Electrical Engineering*, 2026. doi: 10.61784/jcsee3130. URL <https://doi.org/10.61784/jcsee3130>.
- [29] Rajkumar S. Nagarjun AV. Quantum deep learning-enhanced ethereum blockchain for cloud security: intrusion detection, fraud prevention, and secure data migration. *Scientific reports*, 2025. doi: 10.1038/s41598-025-22408-1. URL <https://doi.org/10.1038/s41598-025-22408-1>.
- [30] Caleb Geren; Amanda Board; Gaby G. Dagher; Tim Andersen; Jun Zhuang. Blockchain for large language model security and safety: A holistic survey. *arXiv (Cornell University)*, 2024. doi: 10.48550/arxiv.2407.20181. URL <https://doi.org/10.48550/arxiv.2407.20181>.

- [31] I-Fang Su; Shun-Ming Wang; Yu-Chi Chung; Yi-Hsien Tsai. A smart contract vulnerability detection manner based on large language model. *Lecture Notes in Electrical Engineering Proceedings of the 7th International Conference on Knowledge Innovation and Invention, Volume 1*, 2026. doi: 10.1007/978-981-95-2113-5_2. URL https://doi.org/10.1007/978-981-95-2113-5_2.